



Literature Review

Topic: Cybersecurity threats in IoT for the Power and Utilities sector (Smart Grids and SCADA)

(Research Methods and Professional Practice)

Student name: Abdulrahman Husain Ahmed Alhashmi

Student ID: 33246

Date: 07/12/2025

Contents

Abstract	3
1. Introduction.....	3
2. Method for locating and screening sources	5
3. Conceptual background	5
4. Sector needs and constraints	5
5. Threats and attack scenarios	6
6. Controls and their reported effects	6
7. Evidence base and methods in the literature	7
8. Legal, ethical, and social points	7
9. Discussion.....	7
10. Gaps and future work.....	8
11. Conclusions and recommendations	8
References	10

Abstract

Smart grids and SCADA setups now host large groups of IoT devices. Sensors, RTUs, gateways, and cloud back-ends boost sight and command. They widen the attack face too.

This review blends peer-reviewed papers, sector rules, and regulator advice. It tackles three questions: which threats repeat in power firms, which controls cut risk in daily work, where proof stays thin.

The review spans 2010–2025. It targets transmission and distribution kit, AMI, substation links, field protocols, remote paths, and head-end gear. It flags shared attack routes—weak logins, unsigned code, protocol flaws on old ties, supply-chain flaws, and privacy slips in AMI info. It rates controls with firm backing from sources: zoning via allowed flows; safe protocol shapes and time guards (e.g. IEC 62351); true asset tags and signed patches; OT-fit watch with base rules and protocol scans; tight remote entry with short tokens and session logs. Test sites and case logs note wins: less side-step paths, sharp change checks, swift drift spots.

Gaps linger. Few studies hold long field tracks. Key handling at AMI scale proves tough. Old device packs curb crypto strength at edges. The blend backs layered guards rooted in sector guides (NIST 2015; NIST 2014; IEC 2018; ENISA 2017), small trials on mock rigs, and phased starts that match ops bound. Use these points to map clear next moves sans plant risks.

1. Introduction

Power firms digitise fast. They link field gear, substations, control rooms, and data hubs. This aids reliability, spreads energy sources, and trims costs. Links also let foes enter. A clear review sorts solid facts from mere ideas.

- Spot threats that repeat in smart-grid and SCADA IoT setups.
- Check defences that claim to lower cyber risks in live work.
- Rate the proof strength and kind for those claims.
- Find gaps that need focused study and tests.

Readers: security staff, ops heads, and regulators in utilities. Others: graduate students. Scope: transmission and distribution. Focus on AMI, substation nets, field links, remote gateways, and core systems. Sources from 2010 to 2025 mix experience with new views.

Context and scope

Sector: power transmission and distribution. Assets: smart meters, substation networks, field tools and gates, remote jump servers, head systems. Protocols: IEC 60870-5-104, DNP3, Modbus/TCP, time-sync links. Time frame: 2010-2025, to mix firm advice with fresh real data. Readers: security staff, ops heads, regulators, graduate students who want steps to take now.

Why this review matters now.

Utility IoT groups grow big and mixed for ten years back. Cloud ties and seller remote links spread wide. Rules exist, yet take-up differs; real-world proof stays thin. Clear sight aids: what proves out in field, what lacks tests.

Key questions

What threat types show up often in power firms and like OT sites? Which fixes boost data soundness, uptime, privacy, or fix speed? Where do works lean on brief runs, slim data, or untested guesses?

What counts in?

Papers from checks, set rules, agency reports. Favours works that share data sets, test sites, true cases. Skips pure ideas sans methods or clear proof trails.

Planned outputs.

Short chart of top threats linked to power gear. Ranked fixes with real reasons, trade-offs known. Brief gaps list to steer tests and work: key swaps at meter scale, old gear limits, shared safe logs.

Ways to use this review.

Grid ops lead. Pick top fixes for fast gains: zones and set flows, signed updates, strict remote rules. Strategy role? Shape tests and buys from gaps: safe protocol sets, parts lists, timed seller access. Research here? Aim for long-run data, side-by-side loads, staff factor proof.

2. Method for locating and screening sources

Search plan: used IEEE Xplore, ACM Digital Library, ScienceDirect, IET. Got standards from NIST, ENISA, IEC. Key words mixed ideas and real terms. Like "smart grid security", "SCADA cyber security", "IEC 62351", "ICS monitoring", "AMI privacy", "substation network". Kept sources tied to utilities. Needed peer review, standard status, or regulator origin. Favoured studies with data sets, test sites, or real cases.

Screen steps: first scan titles and summaries. Then full read with short note form. Coded each for setup context, threat kinds, defence groups, method, and proof level. Like rule agreement, lab test, site case, or poll. This keeps things open and aids fair compares across varied works.

3. Conceptual background

3.1 Architecture and trust boundaries

Smart grids cross zones with set trust levels. Field layer has sensors, smart devices (IEDs), RTUs, meters. Substations hold relays, gateways, process, and station nets. Control centres run SCADA servers, data logs, EMS/DMS apps. Enterprise and cloud do analysis, asset care, billing. Gateways join OT and IT, often over protocol shifts. IEC 60870-5-104, DNP3, Modbus/TCP stay common in field. IP links rule upper parts. Time needs and safety limits change choices in running plants.

3.2 Standards that shape practice.

Four main rules show up in utility advice and study. NIST SP 800-82 for ICS security. NISTIR 7628 for smart-grid security and privacy. IEC 62351 for power protocol security and time sync. ENISA basics for IoT. They push zones and safe paths, secure protocol forms, ID and key care, remote access rules, and OT-fit monitoring.

4. Sector needs and constraints

Operational demands shape security choices. Safety tops all. Reliability and set timing stay firm. Gear lasts decades. Fleets mix vendors and software types. Patch times stay brief, rare. Remote access aids fixes and vendor aid. AMI size tests ID store, key swaps, cuts. Good security fits these bounds, not fights them.

5. Threats and attack scenarios

5.1 Field and edge

Seen issues: weak or shared logins on RTUs, gateways. Unsigned or poor-check firmware. Open fix paths. Time-sync fakes twist guard logic, state checks. Site visits risk physical entry. Portable drives, laptops cross trust lines.

5.2 Substation and network

Flat nets and loose routes let side moves from one spot. Old protocol flows lack auth or checks. Open to replays, command slips. Remote paths turn pivots if jump boxes skipped, logs spotty, accounts shared.

5.3 AMI and back-end

Core platforms rule millions of devices. Breach scales quick. Meter data shows home use, habits, raises privacy flags. Supply-chain bugs in updates hit field and core. Cloud shares duties. Teams, vendors must own clear parts.

6. Controls and their reported effects

6.1 Zoning and allow-listed flows.

Split process, ops, enterprise zones with tight paths. Top advice across works. List-ok flows, jump boxes for remote work, one-way data cuts side moves, speeds breach hunts. Firms that set these note clear changes, less hidden links, quick fixes.

6.2 Protocol protections and time security

IEC 62351 safe forms add secret, whole messages, role access, clock guards to power links. In use, staff trust remote orders more. Beats replay, fakes. Costs: gear swaps, key holds, gateway speed, training. If field gear lacks power, add at group points till swaps grow.

6.3 Identity, inventory, and secure updates

Right asset lists, unique IDs, signed firmware cuts detect time for drifts, holds breaches. Firmware and software part lists aid checks, buys. Firms with tight update lines face less shock in faults.

6.4 OT-aware monitoring

Checks fit to plant acts and protocol meanings beat plain IT tools. Parsers for IEC-104, DNP3 lift signal. Base rules, lists cut noise sans weak signs. Schedules, switch plans tie

baselines. Spot shifts soon. Hurdles: good data grabs, season shifts, staff who know processes and logs.

6.5 Remote access discipline

Short-term tokens, two-step checks, session logs, and vendor slots under change rules tie to fewer illegal changes and sharper event reviews. Clear roles and emergency steps cut the pull to share top accounts.

6.6 Mixed or context-dependent results

Two spots need smart choices. Edge-to-edge coding boosts data health but taxes gear; at AMI size, key swaps and blocks take heavy work. Cloud shifts aid data checks and group tasks but add delays and link risks; key loops must stay near the site. Sign-check tools alone fall short and pair best with approved lists and basic rules.

7. Evidence base and methods in the literature

Studies cover ICS surveys, SCADA risk checks, lab tests on protocol safety and threat spotting, impact models from control math, and AMI data privacy looks. Strong points include firm agreement on zones and access rules, solid protocol tips, and better lab setups. Weak spots show few long-term site data sets, rare side-by-side tests at same loads, and light looks at full-life and fix limits. Key takeaway: gains need shared data, safe masking, and fair cross-firm tests.

8. Legal, ethical, and social points

Privacy: detailed use data shows who is home and what runs; build-in privacy and clear opt-ins are key. Safety: safety guards must not block protection tools or site views; test on fake setups cuts roll-out risks. Buying: bids must demand signed fixes, parts lists, session logs, and timed vendor entry. Staff: train OT-IT groups together and keep short guides to cut faults and ease checks.

9. Discussion

Proof builds a real mix: smart-grid and SCADA IoT safety blends linked controls, not one tool. Zones and paths block spread. Safe protocol sets and time guards keep orders true. True lists and signed fixes build solid bases. OT-fit checks give sight without overload. Access rules fix common slips. Choices matter at edges where gear limits and fix times bind picks, and in cloud where group wins weigh against delays and ties.

10. Gaps and future work

Legacy fleets: many IEDs and RTUs lack modern security features. Research and guidance should develop pragmatic migration roadmaps that blend gateway protections, compensating controls, and phased replacement tied to safety cases and budget cycles.

Key management at scale: AMI estates hold millions of credentials; comparative studies of rotation, recovery, and revocation are needed with operational effort factored in.

Testbeds and datasets: open, privacy-safe traces from substation-like networks would enable fair comparisons of IDS and monitoring methods.

Human factors: operator workload, alarm design, and handover quality deserve more empirical attention.

Metrics: utilities need a small set of trend measures such as allowed path counts, patch coverage of critical nodes, and time to revoke compromised keys.

11. Conclusions and recommendations

Layered safety holds firm ground. The field wins with plans that stress doable steps fit to site needs. Top setups join zones and approved paths, IEC 62351-linked protocol sets, true lists and signed fixes, OT-fit checks on basic rules, and tight access. Test shifts on fake sites and phase in with safety locks and clear win marks. Also, Data from 2010 to 2025 shows a clear trend. Security in smart-grid and SCADA IoT gets better when utilities use simple, strict controls. Zoning with approved data flows stops side-to-side attacks. Safe protocol settings and time checks boost command safety. Real-time asset lists and signed software fixes cut drift and speed up probes. Monitoring tuned to plant patterns spots issues fast. Strict remote access rules block usual weak spots. Key hurdles include old equipment, key handling for large AMI setups, and thin field records over years. A step-by-step plan, tried on test setups, matches real-world needs and builds trust.

Recommendations for utilities

- Set zones and paths; lock approved lists full length.
- Turn on safe protocol sets on gear and gates that take them.
- Keep current gear lists; sign and check all fix and setup shifts.
- Roll out OT-fit checks with site baselines and basic rules.
- Secure remote entry with two-steps, short tokens, logs, and vendor slots.
- Test shifts first; track few risk stats and check each quarter.

Recommendations for researchers

- Share lab plans, logs, and code checks for repeats.
- Run same-load matches on controls and show impact sizes, not just hit rates.
- Test AMI-big key work with real task limits.
- Mix people factors in alert sets, screen plans, and guide builds.

References

- Cárdenas, A.A., Amin, S. and Sastry, S. (2011) 'Research challenges for the security of control systems', *Proceedings of the 3rd Conference on Hot Topics in Security*, pp. 1–6.
- Cherdantseva, Y., Burnap, P., Blyth, A., Eden, P., Jones, K., Soulsby, H. and Stoddart, K. (2016) 'A review of cyber security risk assessment methods for SCADA systems', *Computers & Security*, 56, pp. 1–27.
- ENISA (2017) *Baseline Security Recommendations for IoT*. Athens: European Union Agency for Network and Information Security.
- Fang, X., Misra, S., Xue, G. and Yang, D. (2012) 'Smart Grid — The New and Improved Power Grid: A Survey', *IEEE Communications Surveys & Tutorials*, 14(4), pp. 944–980.
- Hahn, A., Ashok, A., Lee, S. and Mohsenian-Rad, H. (2013) 'Cyber-physical security of SCADA systems: A survey', *IEEE SmartGridComm 2013*, pp. 1–6.
- IEC (2018) *IEC 62351: Power systems management and associated information exchange — Data and communications security*. Geneva: International Electrotechnical Commission.
- Knowles, W., Prince, D., Hutchison, D., Disso, J.F.P. and Jones, K. (2015) 'A survey of cyber security management in industrial control systems', *International Journal of Critical Infrastructure Protection*, 9–10, pp. 52–80.
- NIST (2014) *NISTIR 7628 Revision 1: Guidelines for Smart Grid Cyber Security*. Gaithersburg, MD: National Institute of Standards and Technology.
- NIST (2015) *SP 800-82 Revision 2: Guide to Industrial Control Systems (ICS) Security*. Gaithersburg, MD: National Institute of Standards and Technology.
- Ten, C.W., Liu, C.C. and Manimaran, G. (2010) 'Vulnerability assessment of cyber security for SCADA systems', *IEEE Transactions on Power Systems*, 23(4), pp. 1836–1846.
- Wang, W. and Lu, Z. (2013) 'Cyber security in the Smart Grid: Survey and challenges', *Computer Networks*, 57(5), pp. 1344–1371.
- Zhang, Y., Wang, L., Sun, W., Green, R. and Alam, M. (2011) 'Distributed intrusion detection system in a multi-layer network architecture of smart grids', *IEEE Transactions on Smart Grid*, 2(4), pp. 796–808.
- ENISA (2017); IEC (2018); NIST (2014); NIST (2015).